武汉大学 国家网络安全学院
SCHOOL OF CYBER SCIENCE AND ENGINEERING·WHU

信息系统安全

（Information System Security）

武汉大学
王鹃

jwang@whu.edu.cn

目录

- 信息系统安全概述
- 软件安全与恶意代码
- 渗透测试方法及工具
- 模糊测试与漏洞挖掘
- 用户身份认证机制
- 访问控制模型
- 操作系统基础安全机制
- 硬件安全与可信计算
- 系统风险评估方法与工具
- 信息系统安全研究新方向

第二章 软件安全与恶意代码

LISS
空天信息安全与可信计算
教育部重点实验室

目录

1 软件安全简介

2 典型软件漏洞

3 恶意软件分类和原理

4 程序加壳和脱壳

5 软件安全开发模型

6 软件漏洞分析及检测工具

1、软件安全简介

软件安全现状

中国国家信息安全漏洞库

软件安全简介

软件安全现状

微软安全公告

1到15个公告，共1425个　　1　第1页，共95页

日期	公告号	知识库号	标题	公告等级
2016/4/12	MS16-050	3154132	Security Update for Adobe Flash Player	严重
2016/4/12	MS16-049	3148795	Security Update for HTTP.sys	重要
2016/4/12	MS16-048	3148528	Security Update for CSRSS	重要
2016/4/12	MS16-047	3148527	Security Update for SAM and LSAD Remote Protocols	重要
2016/4/12	MS16-046	3148538	Security Update for Secondary Logon	重要
2016/4/12	MS16-045	3143118	Security Update for Windows Hyper-V	重要
2016/4/12	MS16-044	3146706	Security Update for Windows OLE	重要
2016/4/12	MS16-042	3148775	Security Update for Microsoft Office	严重
2016/4/12	MS16-041	3148789	Security Update for .NET Framework	重要
2016/4/12	MS16-040	3148541	Security Update for Microsoft XML Core Services	严重
2016/4/12	MS16-039	3148522	Security Update for Microsoft Graphics Component	严重
2016/4/12	MS16-038	3148532	Cumulative Security Update for Microsoft Edge	严重
2016/4/12	MS16-037	3148531	Cumulative Security Update for Internet Explorer	严重
2016/3/8	MS16-036	3144756	Security Update for Adobe Flash Player	严重
2016/3/8	MS16-035	3141780	Security Update for .NET Framework to Address Security Feature Bypass	重要

1到15个公告，共1425个　　1　第1页，共95页

软件安全简介

- 出现软件故障现象的原因是软件存在漏洞。
- “任何软件，不论它看起来是多么安全，其中都隐藏漏洞”。
- 软件安全的目的是尽可能消除软件漏洞，确保软件在恶意攻击下仍然正常运行。

LISS
空天信息安全与可信计算
教育部重点实验室

软件安全简介

- 软件安全三大威胁：
  - ✓ 软件缺陷与漏洞
  - ✓ 恶意软件
  - ✓ 软件非法破解

软件安全简介

软件缺陷

- 指计算机软件或者程序中存在的某种破坏正常运行能力的问题、错误或者隐藏的功能缺陷。
- 缺陷的存在会导致软件产品在某种程度上不能满足用户的需要。

软件安全简介

软件漏洞（Software vulnerabilities/bugs）

指在硬件、软件、协议的具体实现或者系统的安全策略存在缺陷，从而可以使得攻击者能够在未授权的情况下访问或者破坏系统。

漏洞可能来自应用软件或操作系统设计时的缺陷或编码时产生的错误，也可能来自业务在交互处理过程中的设计缺陷或逻辑流程上的不合理之处。

漏洞被触发后将会影响到较大范围的软、硬件设备，包括操作系统本身及其支撑软件，网络客户端和服务器软件，网络路由器和安全防火墙。

软件安全简介

软件漏洞的危害

1、**软件正常功能被破坏**

软件崩溃、拒绝服务等

2、**系统被恶意控制、信息泄露、提权**

攻击者通过精心设计构造攻击程序（Exploit），可以准确地触发软件漏洞，并利用软件漏洞在目标系统中插入并执行精心设计的代码（shellcode/payload），从而获得对目标系统的控制权。

软件安全简介

软件漏洞危害的级别

- **危急**
  漏洞传播影响很大，如无需用户激活的网络蠕虫传播的漏洞
- **高危**
  漏洞的利用会危及到用户数据的机密性，完整性和有效性。
- **中危**
  开发利用该漏洞比较困难，漏洞的利用受限于默认配置，验证等因素。
- **低危**
  漏洞的利用非常困难，或者漏洞的影响不大

软件安全简介

恶意软件(Malware)

恶意软件是指那些设计目的是为了实施特定恶意功能的一类软件程序。

典型的恶意软件包括：

- 计算机病毒
- 特洛伊木马
- 后门
- 僵尸
- 间谍软件
- 勒索软件等

LISS
空天信息安全与可信计算
教育部重点实验室

软件安全简介

恶意软件的危害

- 修改或者破坏已有的软件功能

  恶意软件与运行之后、可以对同一运行环境中的其他软件运行干扰和破坏，从而修改或者破坏其他软件的行为。
- 目标系统中的重要数据被窃取

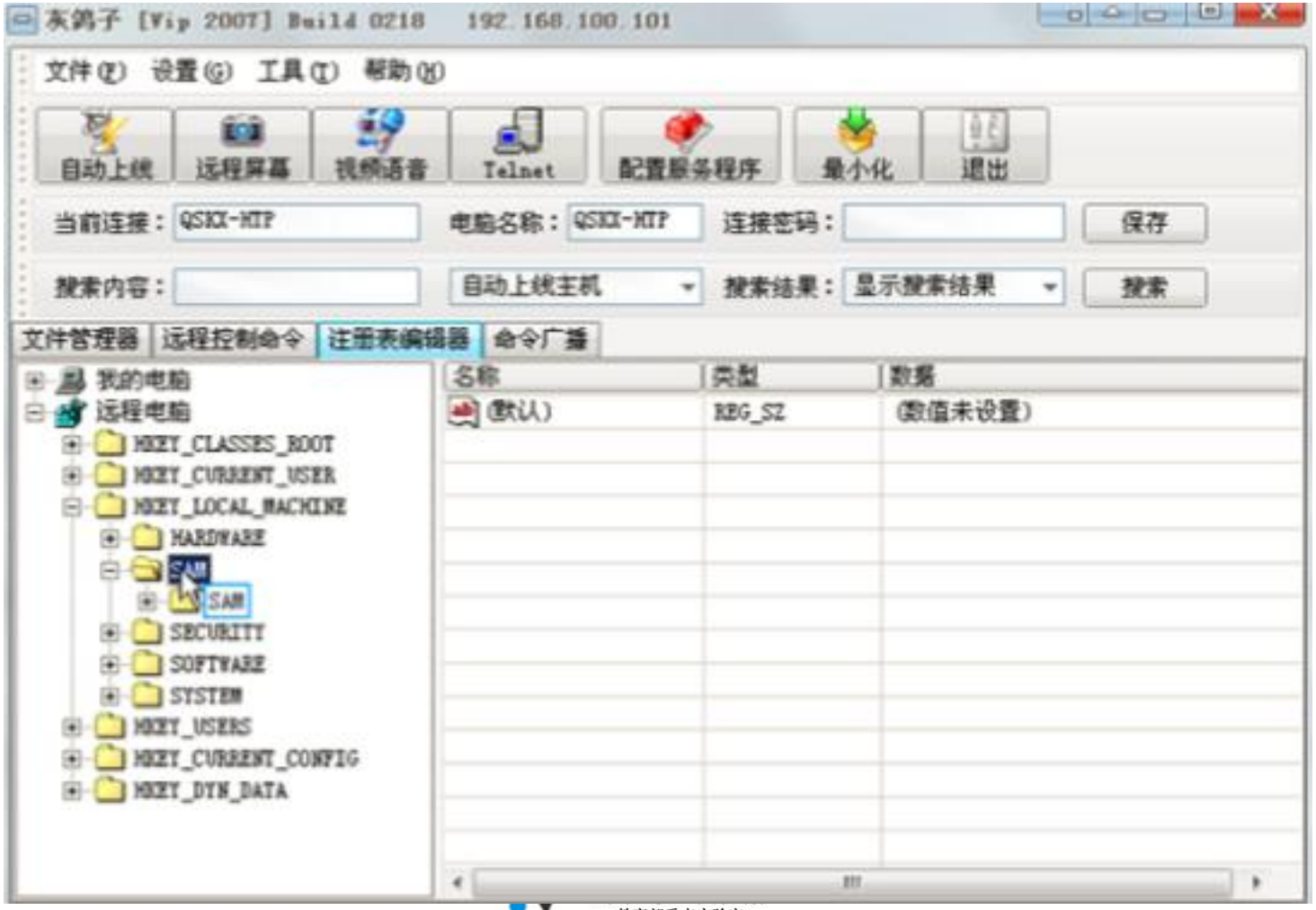
  文件和数据泄露
- 目标系统中的用户行为被监视

  对目标系统进行屏幕监视、视频监视、语音监视等。
- 目标被控制

  木马、僵尸网络

软件安全简介

灰鸽子


灰鸽子 [Vip 2007] Build 0218 192.168.100.101
文件(F) 设置(S) 工具(T) 帮助(H)
自动上线
远程屏幕
视频语音
Telnet
配置服务程序
最小化
退出
当前连接：
电脑名称：
连接密码：
保存
搜索内容：
自动上线主机
搜索结果：
显示搜索结果
搜索
文件管理器
远程控制命令
注册表编辑器
命令广播
我的电脑
远程电脑
HKEY_CLASSES_ROOT
HKEY_CURRENT_USER
HKEY_LOCAL_MACHINE
HARDWARE
SAM
SAM
SECURITY
SOFTWARE
SYSTEM
HKEY_USERS
HKEY_CURRENT_CONFIG
HKEY_DYN_DATA
名称
类型
数据
(默认)
REG_SZ
(数值未设置)

软件安全简介

- 熊猫烧香

  - “熊猫烧香”，是由李俊制作并肆虐网络的一款电脑病毒，熊猫烧香跟灰鸽子不同，是一款拥有自动传播、自动感染硬盘能力和强大的破坏能力的病毒。
  - 不但能感染系统中exe，com，pif，src，html，asp等文件，它还能终止大量的反病毒软件进程并且会删除扩展名为gho的文件（该类文件是一系统备份工具“GHOST”的备份文件，删除后会使用户的系统备份文件丢失。）
  - 被感染的用户系统中所有.exe可执行文件全部被改成熊猫举着三根香的模样。

软件安全简介

三大恶意软件stuxnet、Duqu和flame比较：

特征	stuxnet	Duqu	flame
模块化恶意软件	√	√	√
基于rootkit的内核驱动程序	√	√	使用Fltmgr
有效的数字签名的驱动程序	Realtek, JMicron, C-media		未发现
接入口校验和	√	√	未看见
键盘记录器模块		√	√
PLC功能	√		未发现
通过本地共享感染	√		√非常相似
漏洞利用	√	√	√ 一些源于stuxnet
零日攻击	√	√	未发现
DLL注入系统进程	√	√	√不同
端口80/443，基于C&C的TLS	√	√	发现SSL+SSH
基于访问模块的虚拟文件	√	√	未看见
配置在安全模式下启动	√	√	与stuxnet不同

软件安全简介

软件破解

即通过对软件自身程序进行逆向分析，剖析软件的注册机制，对软件的各类限制实施破解，从而使得非法使用者可以正常使用软件

- 软件破解是对软件版权和安全的一个重大挑战。

2、典型软件漏洞

- 缓冲区溢出
- 整数溢出
- 竞态条件

缓冲区溢出(Buffer Overflow)

“计算机对接收的输入数据没有进行有效的检测，向缓冲区内填充数据时超过了缓冲区本身的容量,而导致数据溢出到被分配空间之外的内存空间，使得溢出的数据覆盖了其他内存空间的数据。”

缓冲区溢出

- 在当前网络与操作系统安全中，50%以上的攻击都是来自于缓冲区溢出漏洞
- 1988年，世界上第一个缓冲区溢出攻击
  –Morris蠕虫在互联网上泛滥，短短一夜的时间全世界6000多台网络服务器瘫痪或半瘫痪
- 缓冲区溢出漏洞（CVE-2018-4407）可导致内核崩溃，苹果多款操作系统均受影响

缓冲区溢出

```
#include "stdio.h"
#include "StdAfx.h"
#include "string.h"
void main()
{
int access ;
char password[5];
//while(1)
//{
access=0;
scanf("%s",password);
if (strcmp(password,"12345") == 0)
access = 1;
if (access != 0)
printf("Welcome back\n");
else
printf("Error\n");
//}
}
```

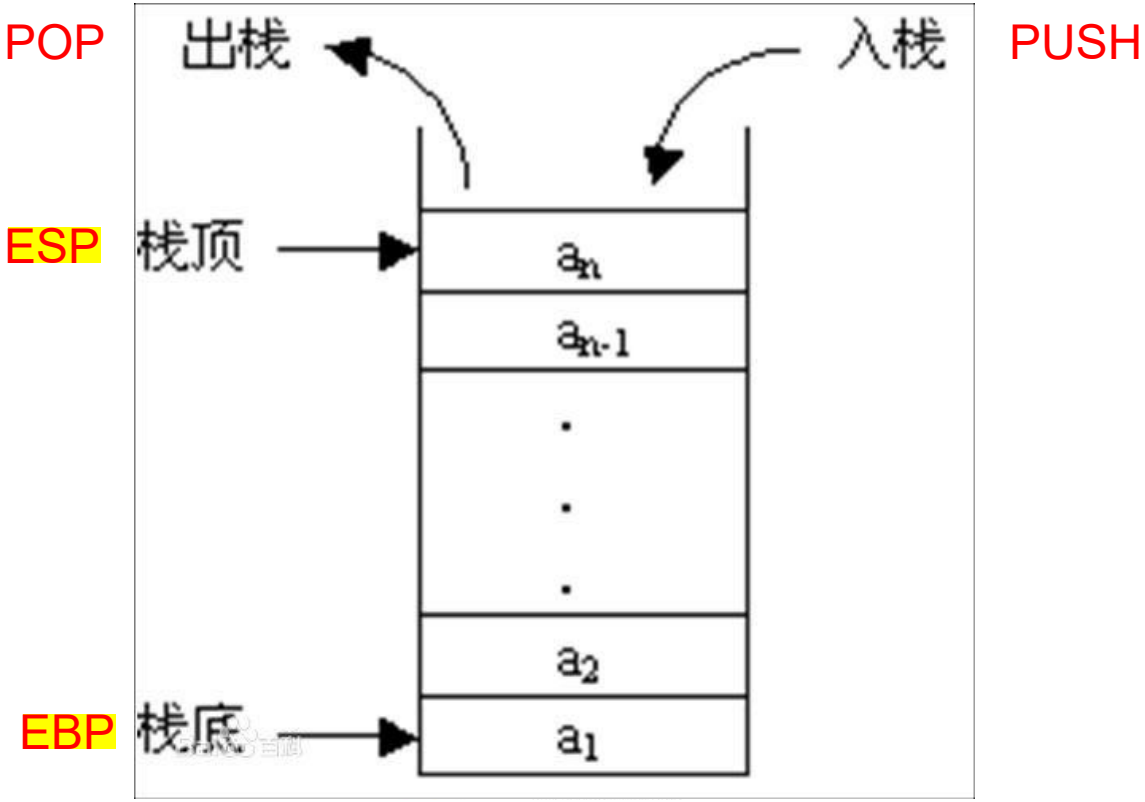
缓冲区溢出！！

VS编译
OD分析

空天信息安全与可信计算
教育部重点实验室

缓冲区溢出

- 栈(stack)
  - 一种先进后出的数据结构，在程序中用于存放函数的参数值，局部变量值。



缓冲区溢出

汇编代码：（观察程序执行过程中堆栈的变化）

PUSH EBP

MOV EBP,ESP

SUB ESP,0E4

PUSH EBX

PUSH ESI

PUSH EDI

LEA EDI

…… 参见OLLybdg的汇编代码

缓冲区溢出覆盖返回地址

```
void main()
{
int access ;
char p[44]={"0"};
//while(1)
//{
access=0;
FILE *fp;
LoadLibrary(_T("user32.dll"));
//LoadLibrary("user32.dll");
if(!(fp=fopen("password.txt","rb")))
{
exit(0);
}
fscanf(fp,"%s",p);
```

OD分析

缓冲区溢出覆盖返回地址

```
//fread(p,sizeof(p),1,fp);
 printf("数据已经读取到%s\n", p);
 fclose(fp);
if (strcmp(p,"12345") == 0)
access = 1;
if (access != 0)
printf("Welcome back\n");
else
printf("Error\n");
//}
}
```

OD分析

缓冲区溢出覆盖返回地址

SHELL CODE:

shellcode就是在利用溢出攻击溢出时要值入的代码,也就是溢出后去执行的代码

33DB53685CFC4200685CFC420053B83465D677FFD0909090909090909090
909090909090909090909090909090909090999090909090909090909090909
0909090903CFF1200

工具：OD+WINHEX　系统WinXP

LISS
空天信息安全与可信计算
教育部重点实验室

整数溢出(Integer Overflow)

➢整数

- 有符号整数和无符号整数
- 计算机语言中整数类型都有一个取值范围
- N位整数，则有2^N取值范围

整数溢出

➢整数溢出

- 两个整数进行运算时，若其结果大于最大值（上溢）或者小于最小值（下溢）就是溢出。

LISS
空天信息安全与可信计算
教育部重点实验室

整数溢出

```
#include <stdio.h> int main(void) {
 short i = 32767;
unsigned short j = 65535;
 unsigned short k = 0; // 上溢例子
printf("%hd %hd %hd\n", i, i+1, i+2); // 上溢例子
printf("%hu %hu %hu\n", j, j+1, j+2); // 下溢例子
printf("%hu %hu %hu\n", k, k-1, k-2); return 0;
}
```

整数溢出

```
F:\AmuseOneself\StudyNotes\C-Language\Examples\55>gcc toobig.c -o toobig.exe

F:\AmuseOneself\StudyNotes\C-Language\Examples\55>toobig.exe
32767 -32768 -32767
65535 0 1
0 65535 65534

F:\AmuseOneself\StudyNotes\C-Language\Examples\55>_
```

整数溢出

➢整数溢出

编译器类型	数据类型	数据名称	最小值	最大值
VC++ 6.0	unsigned short	无符号短整型	0	65535
	short	短整型	-32,768	32,767
	unsigned int	无符号整型	0	4,294,967,295
	int	整型	-2,147,483,648	2,147,483,647
	unsigned long	无符号长整型	0	4,294,967,295
	long	长整型	-2,147,483,648	2,147,483,647
	unsigned __int64	无符号64位整数	0	18,446,744,073,709,500,000
	__int64	64位整数	-9,223,372,036,854,770,000	9,223,372,036,854,770,000
VS2012 C#	ushort	无符号短整型	0	65535
	short	短整型	-32,768	32,767
	uint	无符号整型	0	4,294,967,295
	int	整型	-2,147,483,648	2,147,483,647
	ulong	无符号长整型	0	18,446,744,073,709,500,000
	long	长整型	-9,223,372,036,854,770,000	9,223,372,036,854,770,000

整数溢出

整数溢出

2018年4月22日，黑客对BEC智能合约发起攻击，凭空取出

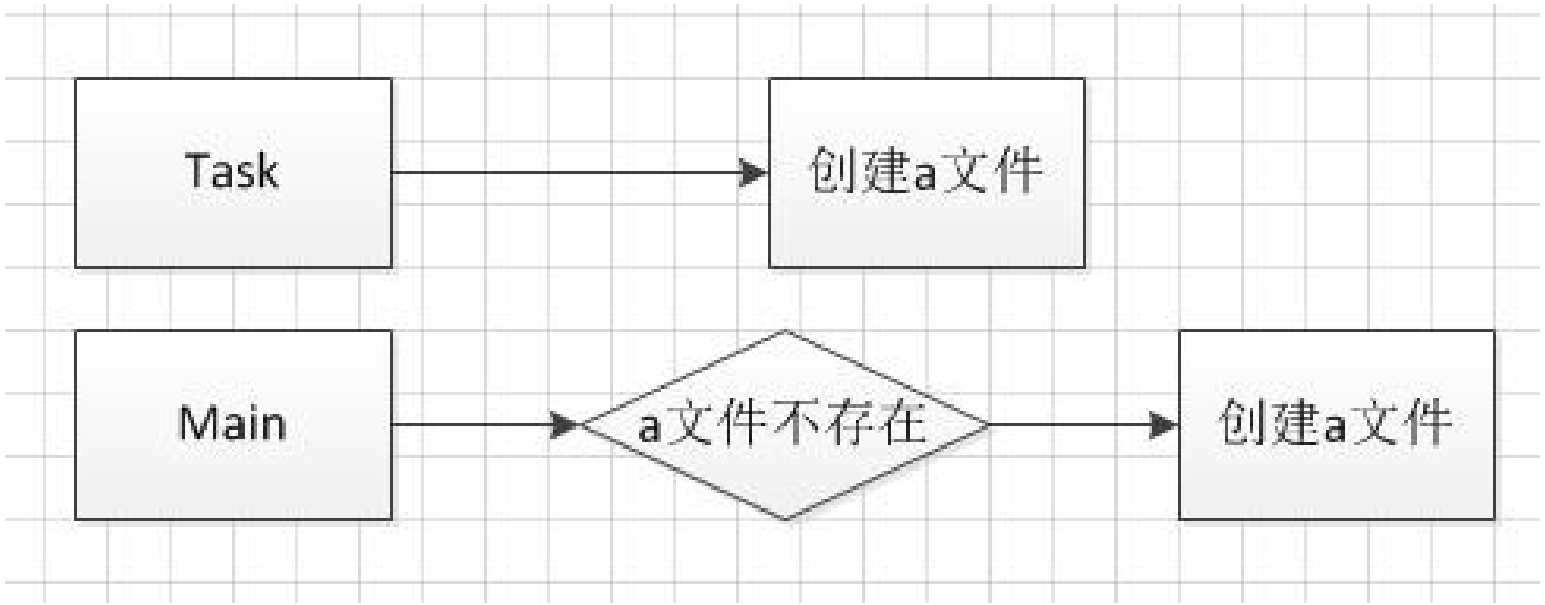
57,896,044,618,658,100,000,000,000,000,000,000,000,000,000,000,000,000,000,000,000.792003956564819968 个BEC代币并在市场上进行抛售，BEC随即急剧贬值，价值几乎为0，该市场瞬间土崩瓦解。

LISS
空天信息安全与可信计算
教育部重点实验室

竞态条件（Race Condition）

- 当两个线程竞争同一资源时，如果对资源的访问顺序敏感，就称存在**竞态条件**
- 计算的正确性取决于多个线程的交替执行时序时，就会发生竞态条件。

竞态条件



竞态条件

➢竞态条件（Race Condition）

```
#include #include int main() {
char * fn = "/tmp/XYZ";
char buffer[60];
FILE *fp; /* get user input */
scanf("%50s", buffer ); if(!access(fn, W_OK)){
①
 fp = fopen(fn, "a+");
  ②
fwrite("\n", sizeof(char), 1, fp);
fwrite(buffer, sizeof(char), strlen(buffer), fp); fclose(fp);
}
else printf("No permission \n"); }
```

LISS
空天信息安全与可信计算
教育部重点实验室

竞态条件

➢脏牛漏洞

Linux内核的内存子系统在处理copy-on-write（COW）时出现竞争条件，导致私有只读存储器映射被破坏，可利用此漏洞非法获得读写权限，进而提升权限。

CVE-2016–5195

3、恶意软件分类和原理

- 计算机病毒
- 木马
- 后门
- Rootkit
- 勒索软件

计算机病毒（Computer Virus）

是编制者在计算机程序中插入的破坏计算机功能或者数据的代码，能影响计算机使用，能自我复制的一组计算机指令或者程序代码。

LISS
空天信息安全与可信计算
教育部重点实验室

计算机病毒

- 计算机病毒的特征
  - 传染性
    - 病毒具有把自身复制到其它程序的能力
  - 非授权性
    - 病毒程序的执行对用户是未知的，即病毒的执行具有某种主动性
  - 隐蔽性
    - 用户不容易察觉病毒程序的存在与执行

计算机病毒

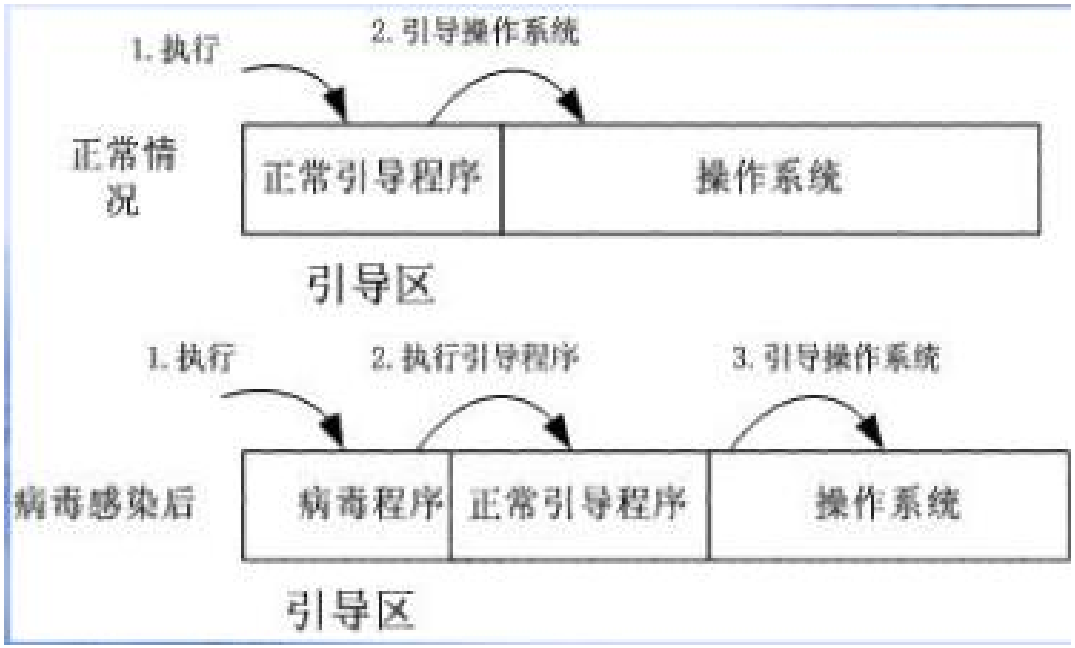
- 计算机病毒的特征
  - 潜伏性
    - 病毒存在于系统中，并等待时机发作
  - 破坏性
    - 干扰系统的执行、管理、数据
  - 不可预见性
  - 可触发性
    - 根据条件触发破坏行动

计算机病毒

- **病毒感染的途径**
  - 引进的计算机系统和软件中带有病毒
  - 染有病毒的游戏软件
  - 非法拷贝中毒
  - 计算机生产、经营单位销售的机器和软件染有病毒
  - 维修部门交叉感染
  - 有人研制、改造病毒
  - 敌对分子以病毒为媒体或武器进行宣传和破坏
  - 通过互联网（访问Web、下载Email和文件等）传入的

计算机病毒

引导型病毒



典型代表：如小球病毒、大麻病毒

计算机病毒

- **引导型病毒特点**
  - 引导部分占据磁盘引导区。
  - 只有在计算机启动过程中，磁盘被引导时，“引导型”病毒才被激活。
  - 具有磁盘引导扇区内容“复原”功能。
  - 修改内存容量，病毒驻留内存。
  - 修改磁盘访问中断，在进行磁盘写操作的时候进行传播。
- 引导型病毒传播方式
  - 正常的操作系统启动过程
  - 感染引导型病毒的操作系统启动

计算机病毒

文件型病毒

- 文件型病毒的主要特点是：
  - 系统执行病毒所寄生的文件时，其病毒才被激活。
  - 有可能直接攻击目标对象，主要是EXE、COM等可执行文件。
  - 修改系统内存分配，病毒驻留内存。
  - 修改系统中断，等待时机进行病毒的发作或再次传播。

计算机病毒

- 宏病毒
  - 宏病毒是使用宏语言编写的程序，可以在一些数据处理系统中运行（主要是微软的办公软件系统，字处理、电子数据表和其他Office程序中），存在于字处理文档、数据表格、数据库、演示文档等数据文件中，利用宏语言的功能将自己复制并且繁殖到其他数据文档里

计算机病毒

- 宏病毒的产生
  - 宏病毒与传统的病毒有很大不同，它不感染.EXE和.COM等可执行文件，而是将病毒代码以“宏”的形式潜伏在Office文件中，主要感染Word和Excel等文件，当采用Office软件打开这些染毒文件时，这些代码就会被执行并产生破坏作用。
- 宏病毒与VBA
  - VBA（Visual Basic for Applications）是Visual Basic的一种宏语言
  - 宏病毒与正常的宏采用相同的语言编写，只是这些宏的执行效果有害。宏病毒也应用了定自动执行这一特点，使用户在打开文件时不知不觉地就运行了这些病毒程序。

计算机病毒

- 宏病毒的表现
  - 自身的传播无破坏性
  - 干扰打印和显示
  - 删除文件
- 宏病毒的特点
  - 容易制造
  - 交叉硬件平台
  - 传播速度极快
  - 具有很好的隐蔽性
  - 破坏性强

计算机病毒

- 脚本病毒
  - 脚本病毒种类比较多，比较常见的就是VBS病毒
  - VBS病毒是用VBScript编写而成，该脚本语言功能非常强大，它们利用Windows系统的开放性特点，通过调用一些现成的Windows对象、组件，可以直接对文件系统、注册表等进行控制

计算机病毒

- 脚本病毒
  - 原理
    - VBS脚本病毒是直接通过自我复制来感染文件的，病毒中的绝大部分代码都可以直接附加在其他同类程序的中间
  - VBS病毒特点
    - 编写简单，破坏力大，感染力强，传播范围大，病毒源码容易被获取，变种多，欺骗性强，实现病毒生产机非常容易

计算机病毒

- 脚本病毒
  - 传播方式
    - Email,局域网共享,感染htm、asp、jsp、php等网页文件
  - 如何获得控制权
    - 修改注册表项，映射文件执行方式，欺骗用户让用户自己执行，desktop.ini和folder.htt

计算机病毒

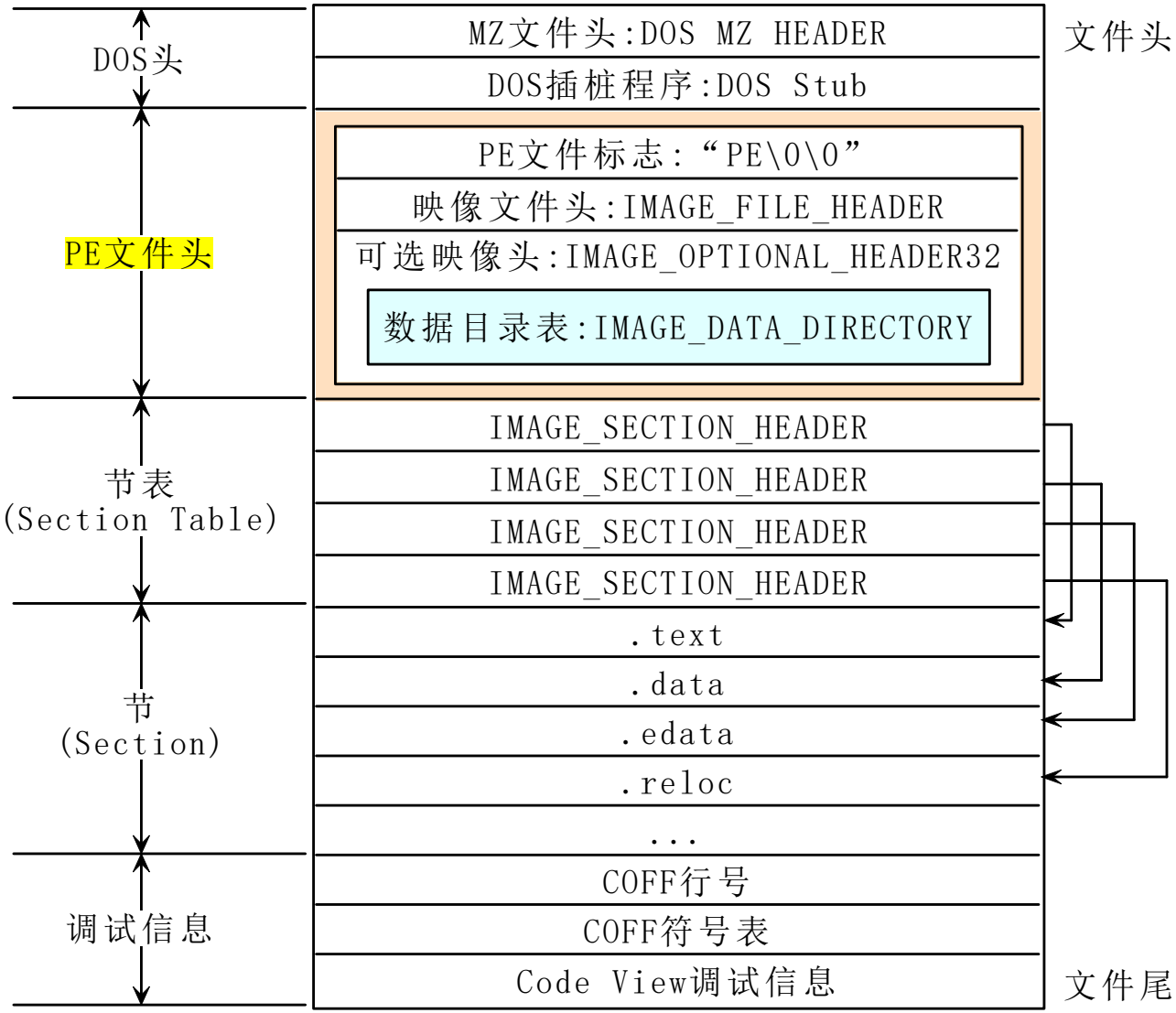
- 脚本病毒
  - VBS脚本病毒的运行条件
    - 绝大部分VBS脚本病毒运行的时候需要用到一个对象：FileSystemObject
    - VBScript代码是通过Windows Script Host来解释执行的
    - VBS脚本病毒的运行需要其关联程序Wscript.exe的支持
    - 通过网页传播的病毒需要ActiveX的支持
    - 通过Email传播的病毒需要OutlookExpress的自动发送邮件功能支持，但是绝大部分病毒都是以Email为主要传播方式的

计算机病毒

- 脚本病毒
  - VBS脚本病毒的防范
    - 禁用文件系统对象FileSystemObject
      - 用regsvr32 scrrun.dll /u命令可以禁止文件系统对象。其中regsvr32是Windows\System下的可执行文件。或者直接查找scrrun.dll文件删除或者改名
    - 删除VBS、VBE、JS、JSE文件后缀名与应用程序的映射
    - 自定义浏览器安全级别
    - 禁止OutlookExpress的自动收发邮件功能

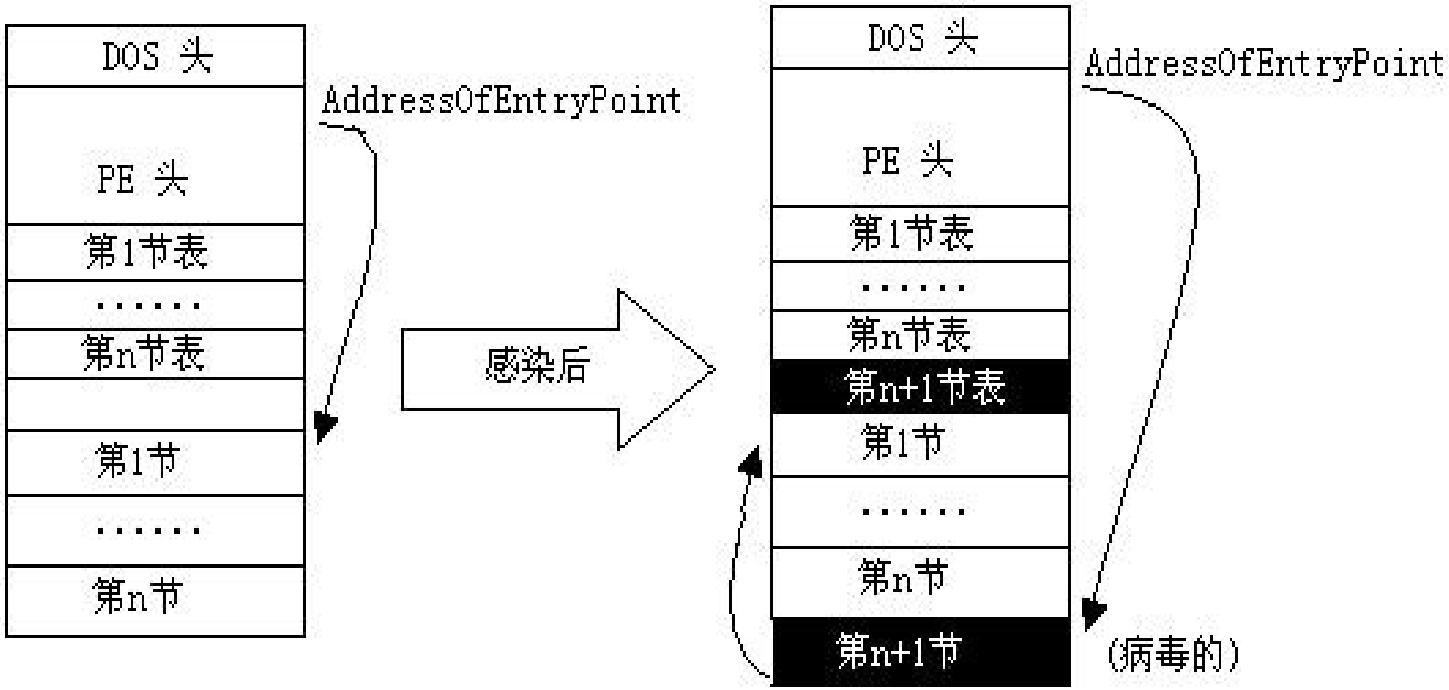
计算机病毒

- PE病毒


DOS头
PE文件头
节表
(Section Table)
节
(Section)
调试信息
MZ文件头:DOS MZ HEADER
DOS插桩程序:DOS Stub
PE文件标志:“PE\0\0”
映像文件头:IMAGE_FILE_HEADER
可选映像头:IMAGE_OPTIONAL_HEADER32
数据目录表:IMAGE_DATA_DIRECTORY
IMAGE_SECTION_HEADER
IMAGE_SECTION_HEADER
IMAGE_SECTION_HEADER
IMAGE_SECTION_HEADER
.text
.data
.edata
.reloc
...
COFF行号
COFF符号表
Code View调试信息
文件头
文件尾

计算机病毒

- 首先判定文件是否是PE文件
- 接下来，添加节

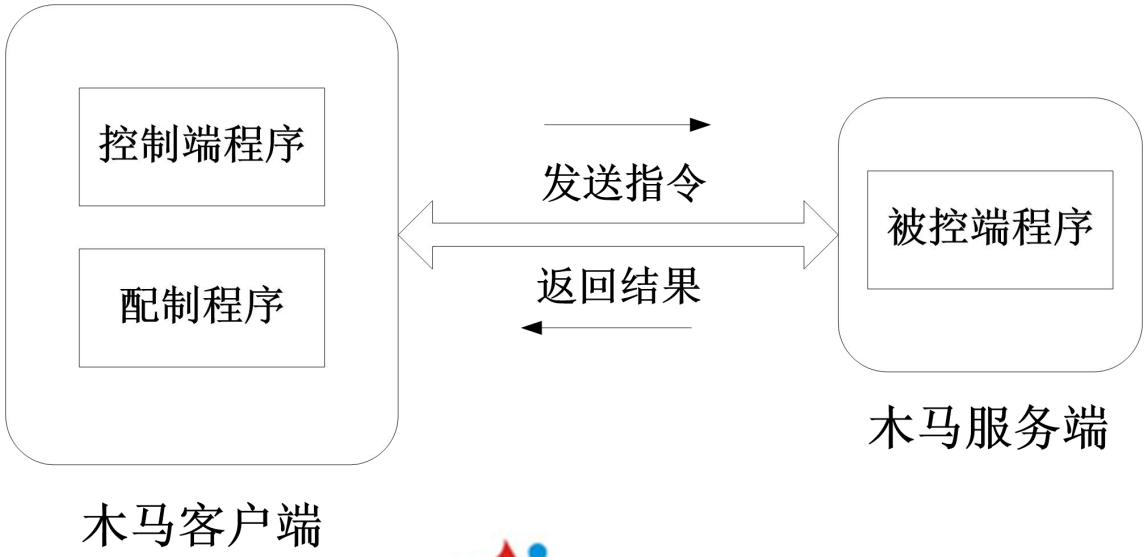


木马

木马（**Trojan**）,也称木马病毒，是指通过特定的程序（木马程序）来控制另一台计算机。

木马

- 木马结构
  - 完整的木马一般由木马配置程序、控制端程序（客户端）和木马程序（服务端程序，即被控端）等三部分组成。



木马

- 木马通常用来控制目标主机，通常由两端组成。
  - 服务端
    - 用来响应控制端发出的指令、执行实际的任务（如文件浏览、上传、下载、执行命令、屏幕监控、摄像头/录音开启及监控）
  - 控制端
    - 方便用来对被控制主机进行操控、发送指令，并显示指令执行的返回结果
    - 通常是图形化控制界面

木马

- 木马的植入方式
  - 伪装欺骗植入
    - 更改后缀名、图标伪装成合法程序
  - 捆绑植入
    - Exe捆绑、文档嵌入、多媒体文件、电子书植入
  - 其他
    - 社会工程，用户习惯

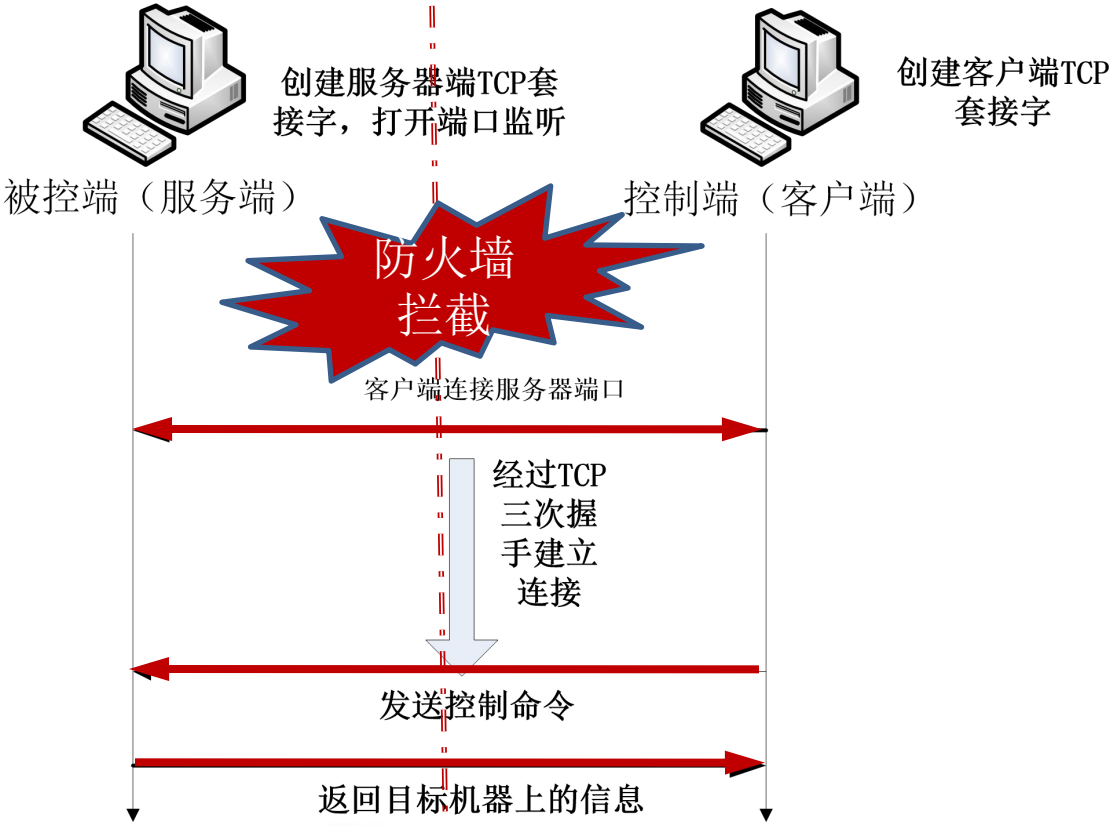
木马

- 木马连接方式
  - 获取连接信息
    - 服务端通知客户端自身的IP地址、端口等信息、第三方控件信息
    - 服务端不主动通知，则客户端主动扫描
  - 建立通信连接
    - 选择可靠的、面向连接的传输层通信协议TCP
      - 正向连接
      - 反向连接

木马

- 正向连接

控制端
主动连接
被控端



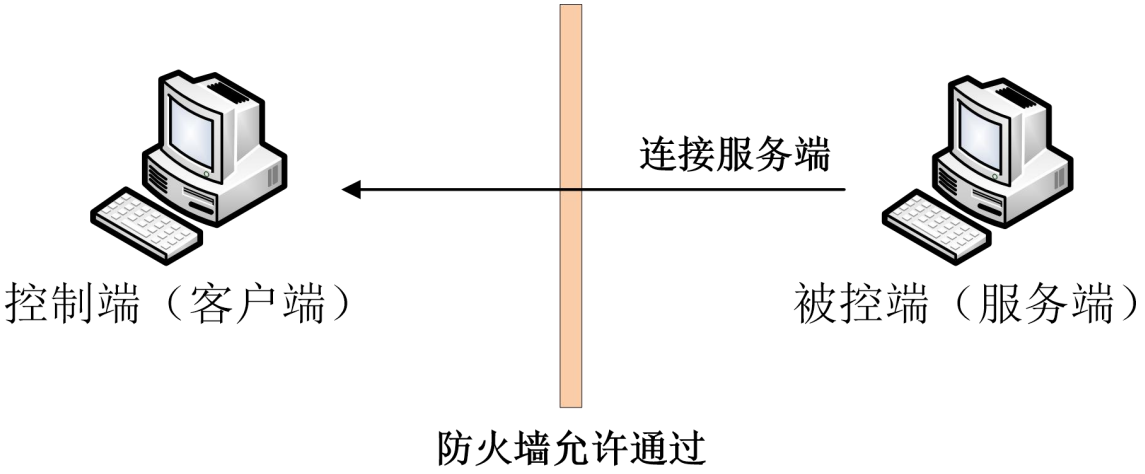
木马

- 优点：
  - 攻击者无需外部IP地址
  - 木马样本不会泄露攻击者IP地址

- 缺点
  - 可能被防火墙阻挡
  - 被攻击者必须具备外部IP地址
  - 定位被攻击者相对困难
    - 目标IP经常变化
    - 目标主机何时上线？

木马

- 反向连接1



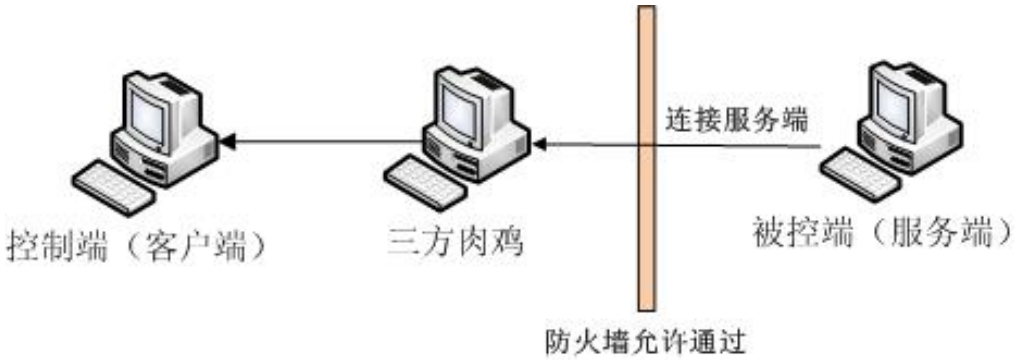
木马

- 优点：
  - 通过防火墙相对容易
  - 攻击目标随时上线随时控制
  - 可以控制局域网内的目标

- 缺点：
  - 样本会暴露控制服务器信息
  - 攻击者通常应当具备外部IP的服务器

木马

- 反向连接2



  - 被控端和控制端都和第三方通信
    - 肉鸡、Web服务器
  - 优点
    - 绕过防火墙，自动连接上线，不易被发现（代理）

后门

- 后门是一个允许攻击者绕过系统中常规安全控制机制的程序，他按照攻击者自己的意图提供通道。
- 后门的重点在于为攻击者提供进入目标计算机的通道。

后门

- 后门 VS 特洛伊木马
  - 如果一个程序仅仅提供远程访问，那么它只是一个后门。
  - 如果攻击者将这些后门伪装成某些其他良性程序，那么那就变成真正的特洛伊木马。
  - 木马是披着羊皮的狼！！它对用户个人隐私造成极大威胁。

后门

- 植入后门
  - 攻击方法
    - 获取尽可能多的用户口令，并不会被管理员察觉或查封
  - 更改配置
    - 例如： rhosts
  - 替换程序（包括源代码，函数库，内核）
    - 要点：时间、校验和
  - 开设新的服务，定时开启服务

后门

- 后门的安装
  - 自己植入（物理接触或入侵之后）
  - 通过病毒、蠕虫和恶意移动代码
  - 欺骗受害者自己安装
    - Email
    - 远程共享
    - BT下载
    - ……

后门

- 植入后门
  - 隐藏
    - 代码：坏扇区， Boot
    - 通讯： TCP， UDP和ICMP
    - Shell后门： TCP/UDP/ICMP

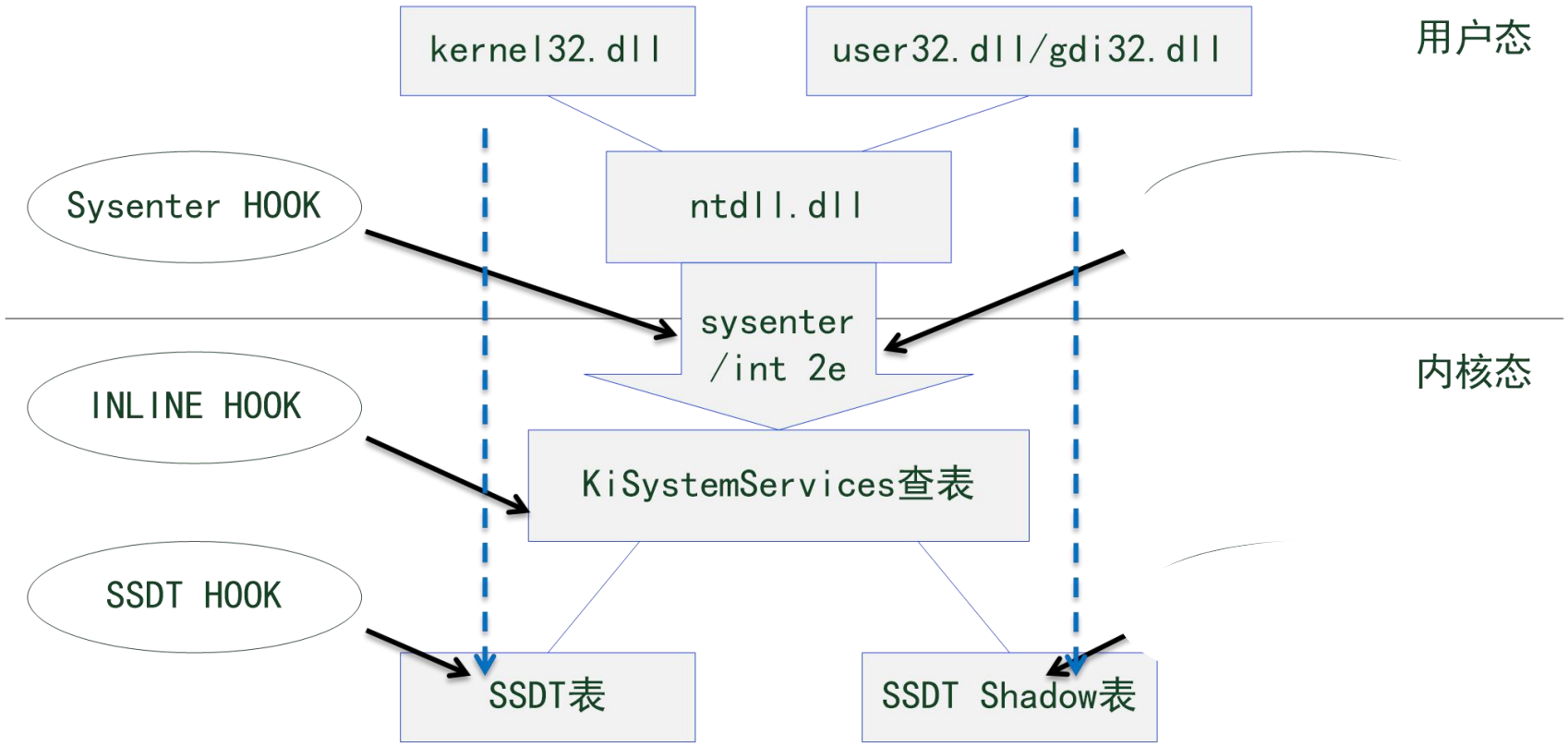
Rootkit

- Rootkit实现隐藏，只是采取一定的措施，使系统“看不到”相应的对象。
  - 系统API查询相应的对象，返回信息
  - 而Rootkit拦截系统API的执行过程或返回结果
  - 将返回结果中指定的对象清除，经过处理后的信息

Rootkit的演化

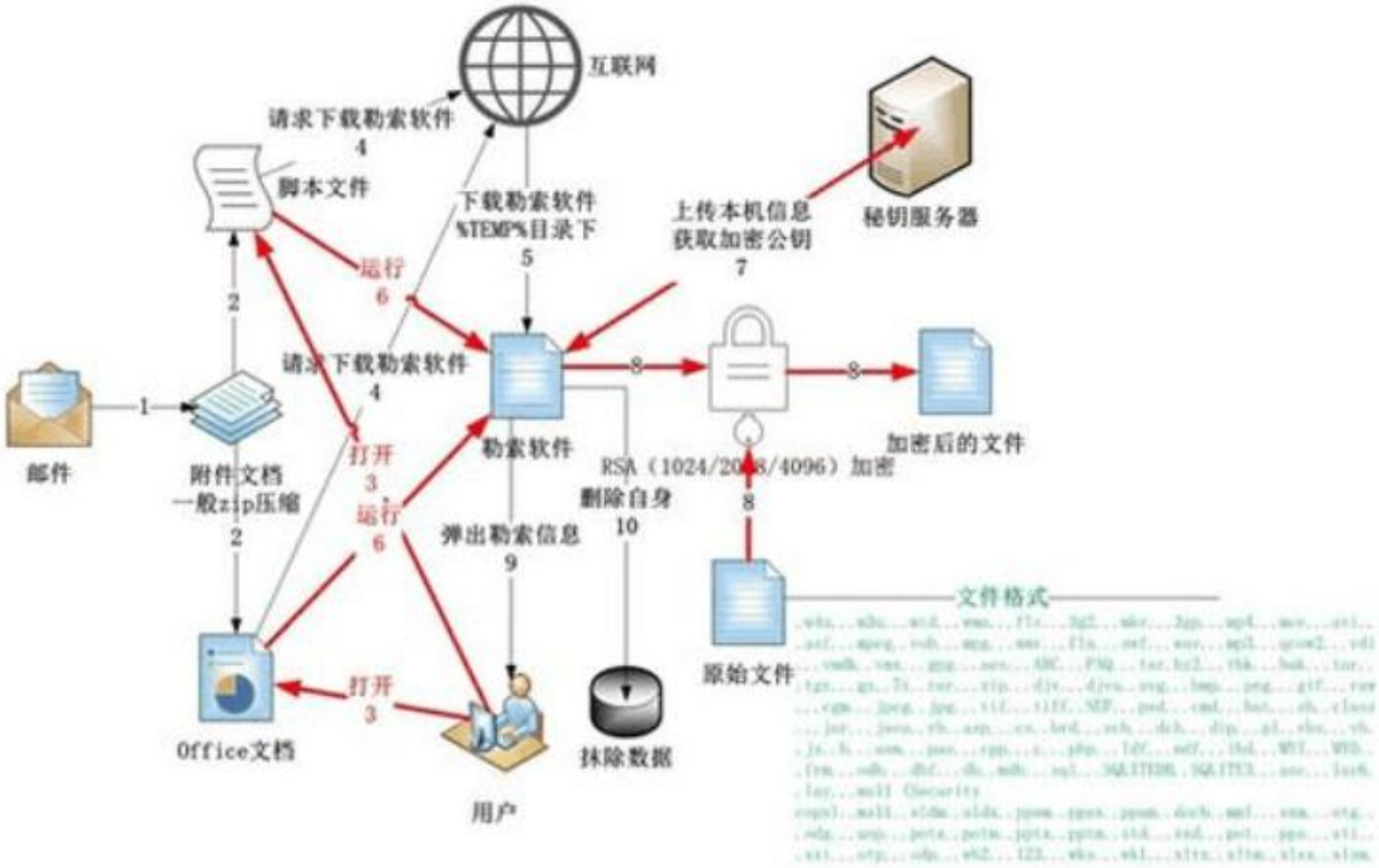
- 第一代Rootkit简单地替换或修改受害者系统上关键的系统文件。
- 第二代的Rootkit大体上基于挂钩技术——通过对已加载的应用程序和一些诸如系统调用表的操作系统部件打内存补丁而改变执行路径。
- 第三代Rootkit技术称为直接内核对象操作，其动态修改内核的数据结构，可逃过安全软件的检测。

Rootkit技术介绍



Windows API 调用流程

勒索病毒


互联网
请求下载勒索软件
4
脚本文件
下载勒索软件
%TEMP%目录下
5
上传本机信息
获取加密公钥
7
秘钥服务器
运行
6
2
请求下载勒索软件
4
8
8
1
邮件
附件文档
一般zip压缩
2
打开
3
运行
6
勒索软件
RSA（1024/2048/4096）加密
加密后的文件
删除自身
10
8
弹出勒索信息
9
文件格式
原始文件
Office文档
打开
3
抹除数据
用户

勒索病毒

Wana Decrypt0r 2.0
Ooops, your files have been encrypted!
Chinese (simpli
我的电脑出了什么问题？
您的一些重要文件被我加密保存了。
照片、图片、文档、压缩包、音频、视频文件、exe文件等，几乎所有类型的文件都被加密了，因此不能正常打开。
这和一般文件损坏有本质上的区别。您大可在网上找找恢复文件的方法，我敢保证，没有我们的解密服务，就算老天爷来了也不能恢复这些文档。
有没有恢复这些文档的方法？
当然有可恢复的方法。只能通过我们的解密服务才能恢复。我以人格担保，能够提供安全有效的恢复服务。
但这是收费的，也不能无限期的推迟。
请点击 <Decrypt> 按钮，就可以免费恢复一些文档。请您放心，我是绝不会骗你的。
但想要恢复全部文档，需要付款点费用。
是否随时都可以固定金额付款，就会恢复的吗，当然不是，推迟付款时间越长对你不利。
最好3天之内付款费用，过了三天费用就会翻倍。
还有，一个礼拜之内未付款，将会永远恢复不了。
对了，忘了告诉你，对半年以上没钱付款的穷人，会有活动免费恢复，能否轮
Payment will be raised on
5/16/2017 02:26:59
Time Left
02:22:35:15
Your files will be lost on
5/20/2017 02:26:59
Time Left
06:22:35:15
About bitcoin
How to buy bitcoins?
Contact Us
bitcoin
ACCEPTED HERE
Send $300 worth of bitcoin to this address:
13AM4VW2dhxYgXeQepoHkHSQuy6NgaEb94
Copy
Check Payment
Decrypt

4、程序加壳脱壳技术

什么是软件加壳

加壳，是一种通过一系列数学运算，将可执行程序文件或动态链接库文件的编码进行改变（目前还有一些加壳软件可以压缩、加密驱动程序），以达到缩小文件体积或加密程序编码的目的。加壳一般是指保护程序资源的方法。

为什么要对软件加壳

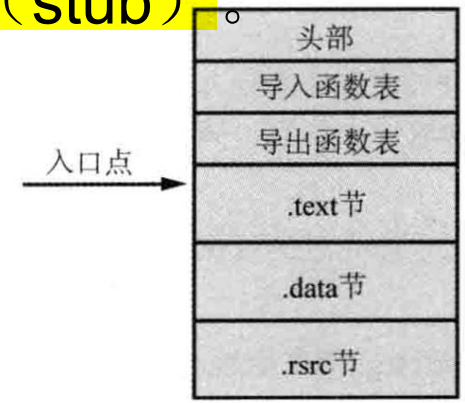
主要目的：

- 是缩减程序的大小
- 阻碍对程序的探测与分析

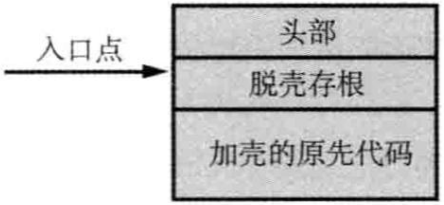
加壳

虽然加壳器的种类繁多，但是它们都遵循相似的模式:

将一个可执行文件转换创建一个新的可执行文件，被转换的可执行文件在这个新的可执行文件中作为数据存储，另外新的可执行文件还包括一个供操作系统调用的脱壳存根（stub）。



加壳前的原可执行文件



加壳后的可执行文件，原代码和已附加的脱壳存根

加壳

没有加壳软件

加壳的软件

加壳程序特征

1. 当使用IDA Pro打开程序时，通过自动分析，只有少量代码被识别
2. 当使用OllyDbg打开程序时，会有程序可能被加壳的警告
3. 程序的节名中包含某款加壳器的标识（如UPX0）。
4. 程序拥有不正常的节大小，例如.text节的原始数据大小为0，但虚拟大小非零。
5. 程序中导入函数很少，导入函数仅有LoadLibrary和GetProcAddress时，应该引起特别注意。

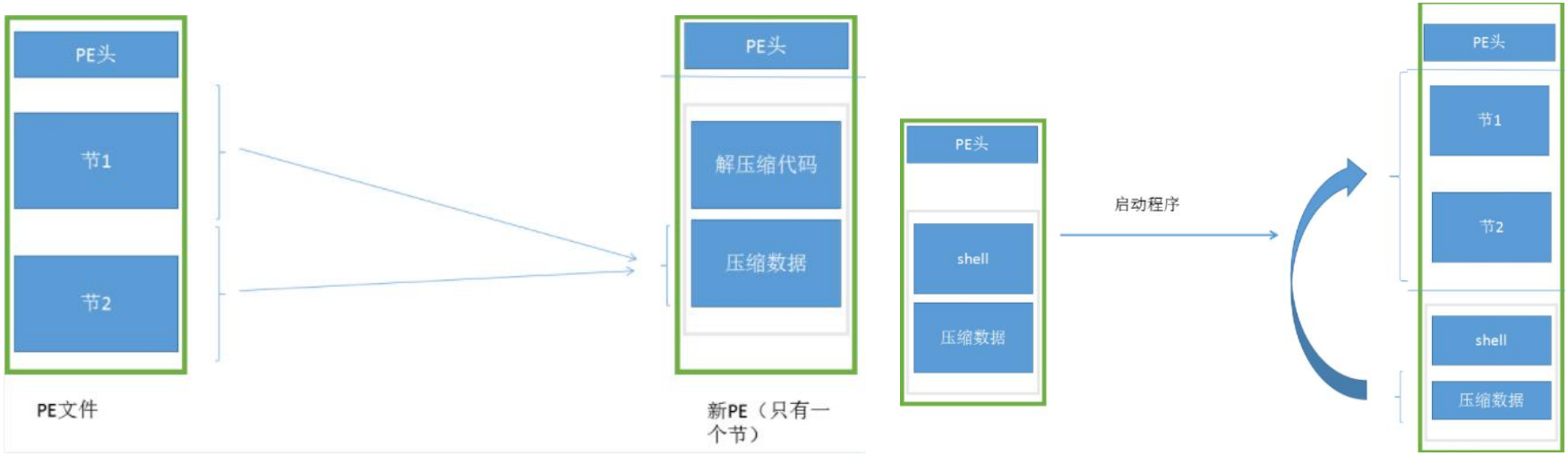
LISS
空天信息安全与可信计算
教育部重点实验室

常见加壳类型

常见加壳器及分类：

- 压缩壳：upx ， aspack ， fsg ， pecompach
- 加密壳：ASProtect ， Armadillo(穿山甲)，EXEcryptor，Themida，ZProtect
- 虚拟机壳：VMProtect

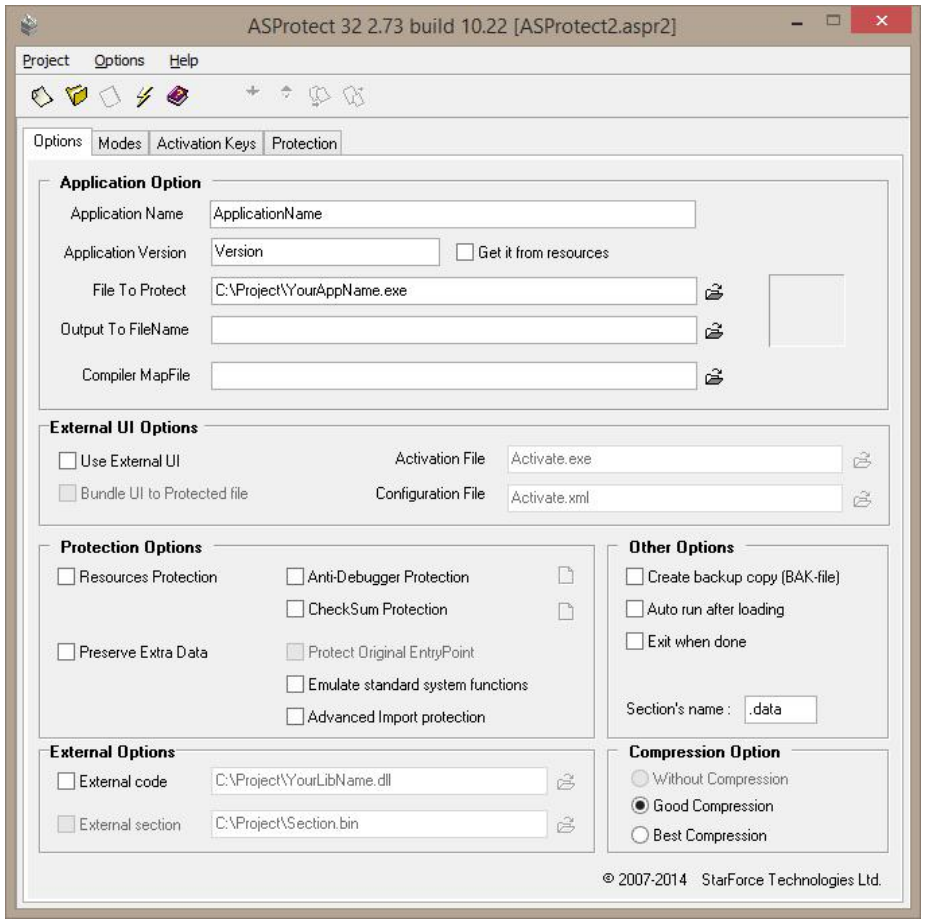
压缩壳原理



压缩壳的原理就是压缩PE文件中节的数据。然后产生新的PE，这个新的PE就成为了一个带壳的PE。而我们运行带壳PE的时候，这时候壳中的解压缩代码开始执行，从而把我们以前压缩数据的节重新映射到内存。

ASProtect

ASProtect 是功能非常完善的加壳、加密保护工具。能够在对软件加壳的同时进行各种保护。如：反调试跟踪、自校验及用密钥加密保护等；还有多种限制使用措施，如：使用天数限制、次数限制及对应的注册提醒信息等。另外，该软件还具有密钥生成功能。

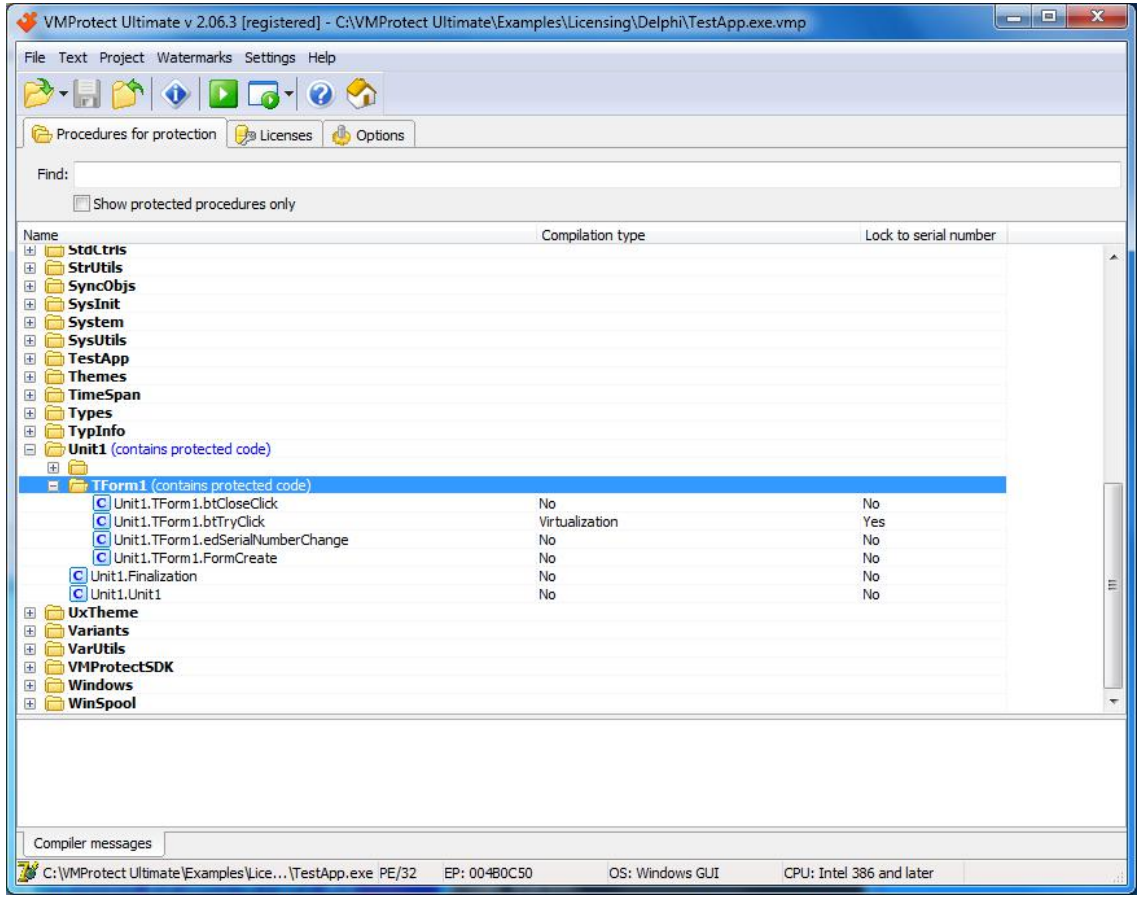


LiSS
空天信息安全与可信计算
教育部重点实验室

VMProtect

VMProtect 是一个软件保护软件。通过这个软件保护的代码部分在虚拟机上执行，这使得被保护的程序很难被分析与破解。

- 将由编译器生成的本机代码(Native Code)转换成字节码(Bytecode)
- 将控制权交由虚拟机，由虚拟机来控制执行
- 转换后的字节码非常难以阅读，增加了破解的复杂性



LISS
空天信息安全与可信计算
教育部重点实验室

常用脱壳方法

自动脱壳方法

自动静态脱壳程序解压缩或者解密一个可执行文件。这是一种最快并且也是最好的脱壳方法。因为这种方法可以在没有运行可执行文件的条件下，将可执行文件恢复为原始状态。**自动静态脱壳程序仅仅针对某个壳，并且对那些用来阻碍分析的壳无效。**

自动的动态脱壳程序运行可执行文件，并让脱壳存根脱出原始的可执行文件。一旦原始的可执行文件被脱壳，它将被写入硬盘，然后脱壳程序重构原始的导入表。

如： UnASPack、UNPEPack等

LISS
空天信息安全与可信计算
教育部重点实验室

常用脱壳方法

手动脱壳方法

有时，加壳的恶意代码可以被一个现有程序脱壳，但多数情况下，必须进行手动脱壳。手动脱壳的关键点在于找到程序OEP。

OEP：(Original Entry Point)，程序的入口点，软件加壳就是隐藏了OEP（或者用了假的OEP）， 只要我们找到程序真正的OEP，就可以立刻脱壳。

常用脱壳方法

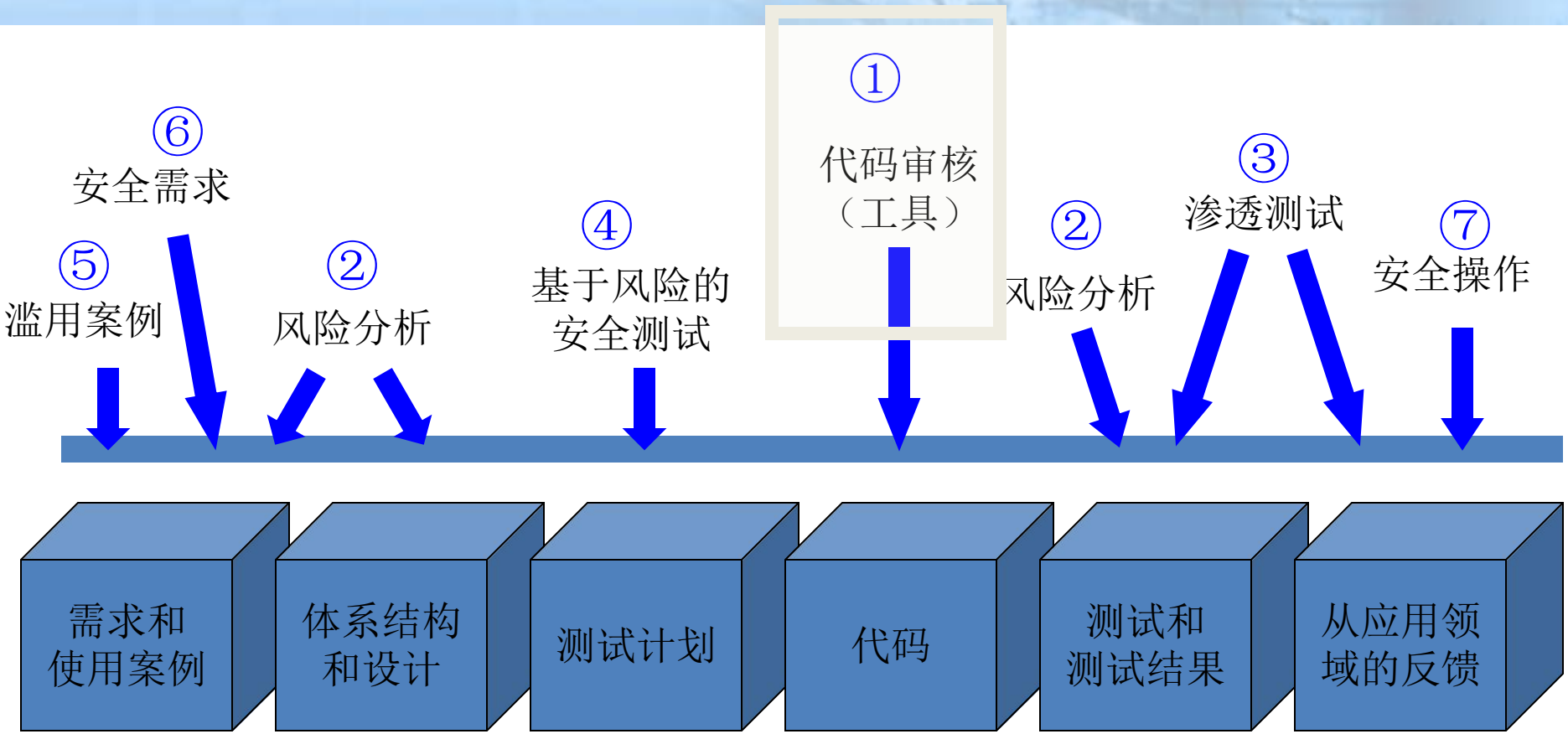
手动查找OEP:

查找OEP可以通过自动工具查找，但是经常会失效，所以大多数情况下需要手动查找OEP。

单步跟踪法是软件脱壳中最基础的脱壳技巧，单步跟踪法就是利用OD的单条指令执行功能，从壳的入口一直执行到OEP，最终通过这个OEP将原程序dump出来。

在使用单步法的脱壳时，要注意关键的CALL，如果CALL指令步过后程序被运行起来则说明跑飞了，需要重新加载程序，下次运行程序后在跑飞的位置使用F7进入CALL中继续执行，循环往复直到找到正确OEP位置。

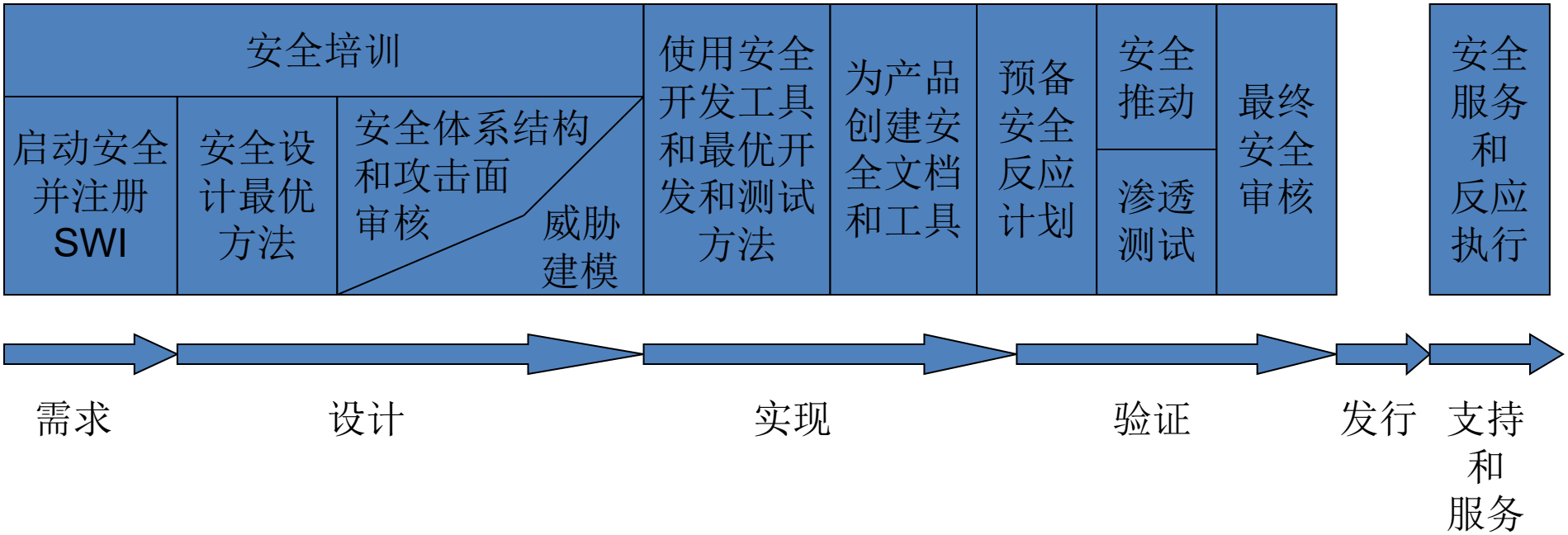
5、软件安全模型



LISS
空天信息安全与可信计算
教育部重点实验室

微软：可信赖计算安全开发生命周期SDLC

- 微软



LISS 空天信息安全与可信计算 教育部重点实验室

SDL

- 其中主要由以下7部分组成：
  - 安全培训(training)：推广安全编程意识
  - 需求分析(requirements)： 寻找安全嵌入的最优方式
  - 系统设计(design): 威胁建模设计
  - 实现(implementation)： 安全开发
  - 验证(verification)： 黑/白盒测试
  - 发布(release)： 最后检查确认
  - 响应(response)：应急响应，bug跟踪解决

6、代码分析工具

IDA

- IDA Pro是目前最好的静态逆向工具。
- 交互式反汇编工具

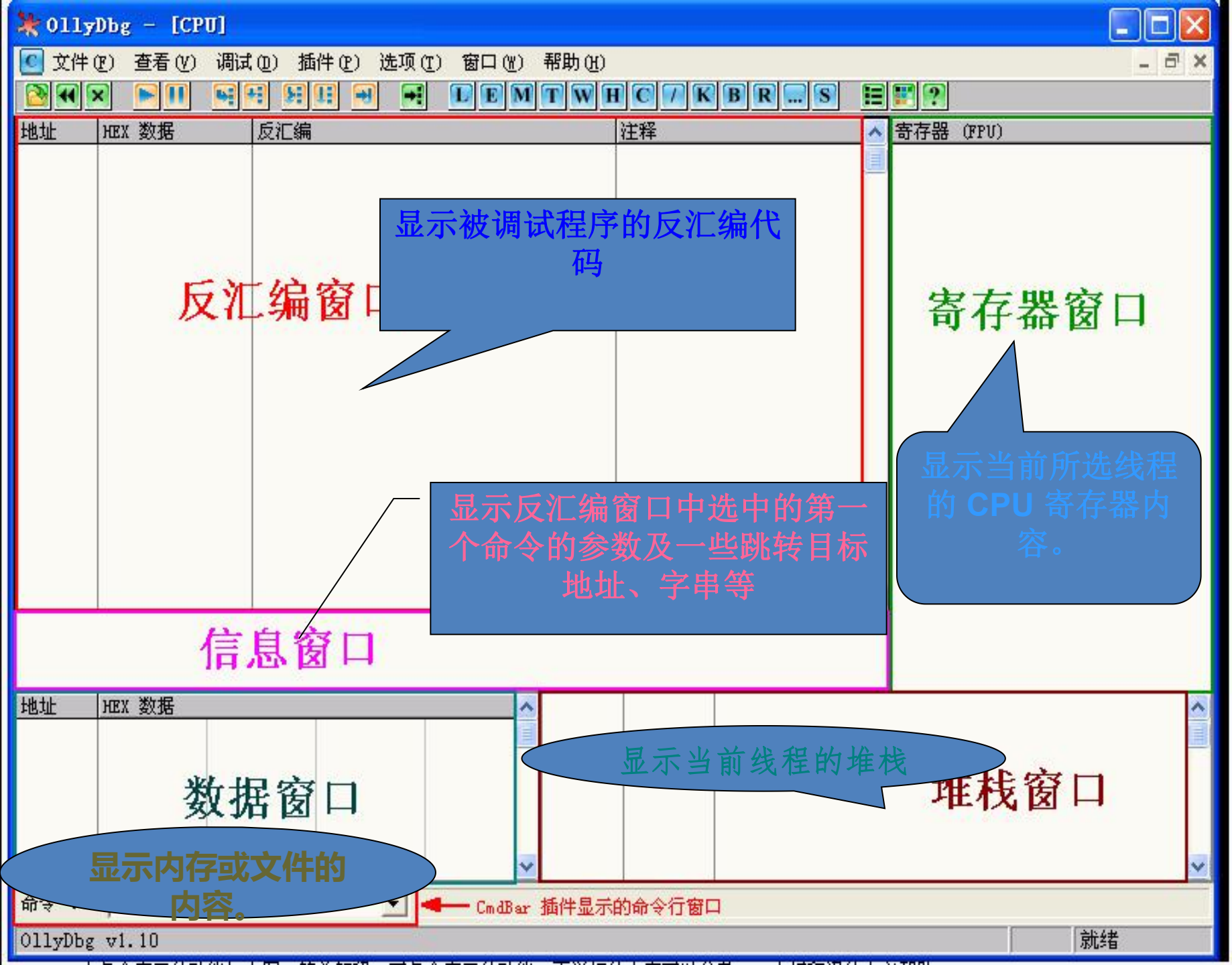
LISS
空天信息安全与可信计算
教育部重点实验室

代码分析工具

OD

- OllyDbg简称OD，是一款具有可视化界面的用户模式调试器，结合了动态调试和静态分析，具有强大的反汇编引擎，能够识别数千个被C和Windows所使用的函数，并能将其参数注释出，能自动分析函数过程、循环语句、代码中的字符串等。

LISS
空天信息安全与可信计算
教育部重点实验室


OllyDbg - [CPU]
文件(F) 查看(V) 调试(D) 插件(P) 选项(T) 窗口(W) 帮助(H)
地址 HEX 数据 反汇编 注释
寄存器 (FPU)
显示被调试程序的反汇编代码
反汇编窗口
寄存器窗口
显示当前所选线程的 CPU 寄存器内容。
显示反汇编窗口中选中的第一个命令的参数及一些跳转目标地址、字串等
信息窗口
地址 HEX 数据
数据窗口
显示当前线程的堆栈
堆栈窗口
显示内存或文件的内容。
命令
CmdBar 插件显示的命令行窗口
OllyDbg v1.10
就绪

代码分析工具

FindBugs

- 有了静态分析工具，就可以在不实际运行程序的情况对软件进行分析。
- FindBugs 是一个静态分析工具，它检查类或者 JAR 文件，将字节码与一组缺陷模式进行对比以发现可能的问题。
- FindBugs 具有缺陷清单及说明。
- Findbugs 可作为eclipse插件使用。

LISS
空天信息安全与可信计算
教育部重点实验室

问题？

谢　　谢！

LISS
空天信息安全与可信计算
教育部重点实验室